Vulnerability Assessment Report

DownUnderNewsz Vulnerability Assessment Report

DownUnderNewsz (The Down Under News)
22 Arthur St
Fairfield VIC 3078, Australia

Flinders University
Sturt Road, Bedford Park SA 5042

October 5, 2026

Report Version: 1.0

CONFIDENTIAL

Table of Contents

List of Figures 4

1 Document Control 5

1.1 Team 5

1.2 List of Changes 5

2 Executive Summary 6

2.1 Overview 6

2.2 Identified Vulnerabilities 7

3 Methodology 9

3.1 Objective 9

3.2 Scope 9

3.3 User Accounts and Permissions 10

4 Findings 11

C1: Server-side template injection in search 11

H1: Flask debug mode enabled in production 12

M1: Application server exposed on port 5000 13

M2: Missing CSRF protection on login and admin APIs 14

M3: Session cookie missing Secure and SameSite flags 15

M4: Missing HTTP security headers 16

M5: No DMARC policy for the corporate domain 17

M6: Public articles API exposes staff account details 18

M7: Unauthenticated comments publish immediately 19

M8: TLS certificate does not cover the apex hostname 20

I1: Contact form does not send messages 21

I2: SSH reachable on the public web server 22

5 Disclaimer 23

A Appendix 24

A.1 Static Appendix Section 24
A.2 Methodology 24
A.3 Limitations 24
A.4 Coverage 24

List of Figures

Figure 1 - Distribution of identified vulnerabilities 8

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Final report	Oct 5, 2026

2 Executive Summary

2.1 Overview

Executive Summary

The Down Under News (DownUnderNewsz) is Australia's independent online-only newspaper, established in 2026. It publishes news across politics, business, technology, sports, entertainment, science, world, and opinion. This report covers an authorized security assessment of the public news website, performed on 5 October 2026.

Overall result

The assessment confirmed **12 findings**. Scored with CVSS v3.1, they are **1 critical**, **1 high**, **8 medium**, and **2 informational**. (Three items — unauthenticated comments, the apex TLS name mismatch, and missing DMARC — were noted as low in the qualitative source write-up; this report keeps the original CVSS vectors, which score those items as medium.)

The most serious issue is in the public search page. Anyone on the internet can type special text that the website treats as programming instructions rather than a normal search. During testing, this exposed internal application settings, including the site's secret signing key (the key value is **not** included in this report). That combination can allow an attacker to forge staff sessions and likely take over the server.

What this means for the business

- **Immediate takeover risk.** The search-page flaw is reachable without logging in. It should be treated as an emergency fix.
- **Secrets already exposed.** Because the signing key was disclosed during testing, existing login sessions should be treated as untrustworthy until the key is rotated and sessions are reset.
- **Developer mode is on in production.** The live site is running with debug enabled. That setting is meant for local testing and can leak internal errors and secrets.
- **Weaker admin protections.** After login, the session cookie can travel over unencrypted HTTP and has no SameSite restriction. Admin actions also lack CSRF tokens.
- **Staff details are public.** The public articles API returns staff emails, usernames, roles, and account status — more than a reader needs.
- **A side door around the website.** The application server is also reachable on port 5000, bypassing the main website's nginx front door.
- **Smaller issues** include missing browser security headers, unauthenticated comments that publish immediately, a TLS name mismatch for visitors who omit "www", no DMARC email policy, public SSH, and a contact form that never actually sends messages.

Highest-priority actions

1. Take the search template injection offline or fix it immediately so user input is never executed as a template.
2. Rotate the Flask secret key and invalidate all sessions.
3. Disable DEBUG in production.
4. Bind Gunicorn to localhost only and block port 5000 from the internet.
5. Add Secure/SameSite cookie flags, CSRF protection, and standard HTTP security headers.

A technical write-up of each finding, with remediation steps for the development team, follows in this report.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
C1	10.0	Server-side template injection in search	11
H1	8.2	Flask debug mode enabled in production	12
M1	6.5	Application server exposed on port 5000	13
M2	6.5	Missing CSRF protection on login and admin APIs	14
M3	5.9	Session cookie missing Secure and SameSite flags	15
M4	5.4	Missing HTTP security headers	16
M5	5.3	No DMARC policy for the corporate domain	17
M6	5.3	Public articles API exposes staff account details	18
M7	5.3	Unauthenticated comments publish immediately	19
M8	4.2	TLS certificate does not cover the apex hostname	20
I1	0.0	Contact form does not send messages	21
I2	0.0	SSH reachable on the public web server	22

Vulnerability Overview

In the course of this penetration test **1 Critical**, **1 High**, **8 Medium** and **2 Info** vulnerabilities were identified:

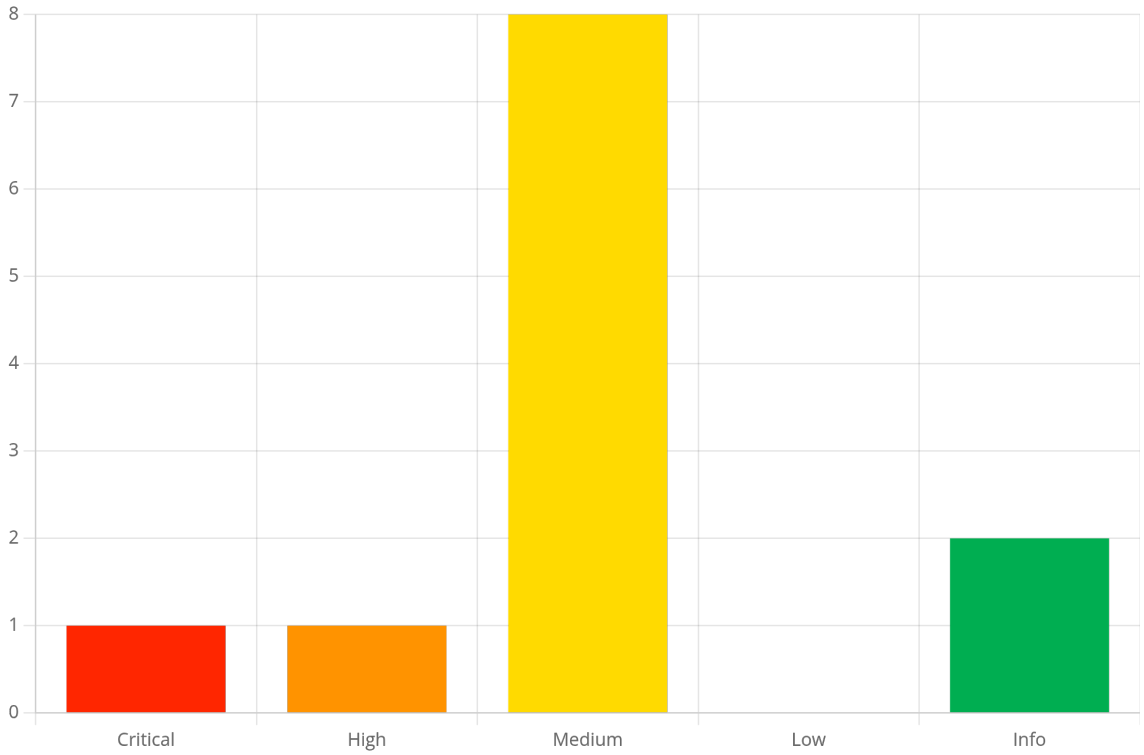


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasiable, seamless and cost-affective such approach is.

3.2 Scope

This assessment covered only owner-approved, in-scope assets for the main news website. Testing was performed on 5 October 2026 after authorization was verified via the main public website.

In-scope (owner approved "Main news website")

System	Description
thedownundernews.online	Apex hostname of the news website
www.thedownundernews.online	www hostname of the news website
51.161.130.70	OVH Australia VPS (Sydney) hosting the site
https://www.thedownundernews.online/	Primary HTTPS site
https://thedownundernews.online/	Apex HTTPS site

Enumerated but excluded from testing by owner selection

- media.thedownundernews.online / 51.161.131.195
- claimed domain thedownundernews.it.com (NXDOMAIN; listed on the site)

Third-party exclusions (not tested)

OVH netblock remainder, Spaceship DNS/mail, Google Fonts, jsDelivr, Flinders University, social networks, and the it.com parent.

Allowed methods

Port discovery, TLS inspection, web crawling, authenticated testing with owner-provided dummy accounts (admin / writer / editor), and non-destructive injection tests.

Forbidden methods

DDoS, malware, phishing, brute force, credential stuffing, password spraying, MFA bypass, lateral movement, and destructive changes.

3.3 User Accounts and Permissions

Owner-provided dummy accounts were used for authenticated CMS review (no passwords are included in this report):

- admin
- writer
- editor

4 Findings

C1: Server-side template injection in search	
Score	10.0 (Critical)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Target	https://www.thedownundernews.online/search
References	• CWE-1336 • CWE-94 • OWASP A03:2021

Overview

Anyone on the internet can type special search text that the website treats as programming instructions. This exposed internal application settings, including the site's secret signing key, and could let an attacker take over the server.

Details

The public search page interpolates the `q` parameter into a Jinja2 template context that is executed server-side rather than treated as plain text.

Verified, non-destructive proofs:

- `/search?q={{7*7}}` rendered the page title and results heading as `49` (saved evidence: evidence/assess-t9/search-ssti.html).
- `/search?q={{7*'7'}}` rendered `7777777`.
- `/search?q={{config.items()}}` rendered Flask configuration, including `DEBUG` set to `True` and the live `SECRET_KEY` value.

The header search box still showed the raw query in one location, while the search results template evaluated it. Testing stopped after this minimum proof; no remote code execution payload was used. With a leaked secret key and template execution, an attacker could forge admin sessions and likely run operating-system commands.

The secret key value is not included in this report.

Recommendation

Stop rendering user input as a template. Pass the search query into the template as a data variable only, or use a precompiled template. Rotate the Flask SECRET_KEY and all sessions immediately. Disable DEBUG in production. Add a regression test that `{{7*7}}` is shown literally, not calculated.

H1: Flask debug mode enabled in production	
Score	8.2 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Target	https://www.thedownundernews.online/
References	• CWE-489 • CWE-215

Overview

The live website is running in developer debug mode. That setting is meant for local testing and can leak internal errors and secrets.

Details

The Flask `DEBUG` configuration value was observed as `True` through the search template-injection proof (`{{config.items()}}`). Debug mode can return detailed tracebacks, local variables, and interactive debugger access on errors. Combined with the template injection, this increases the chance of full application compromise. The secret key itself is not repeated in this report.

Recommendation

Set `DEBUG=False` for the production deployment, ensure the secret key is loaded from a secured environment variable, and restart the application after rotating secrets.

M1: Application server exposed on port 5000	
Score	6.5 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Target	51.161.130.70:5000
References	• CWE-16 • CWE-668

Overview

The Python application (Gunicorn) is reachable directly on port 5000, not only through the public nginx website on 80/443.

Details

Nmap service detection identified Gunicorn on TCP 5000. `http://51.161.130.70:5000/` returned HTTP 200 with `Server: gunicorn` and the same news site. `/admin` and `/api/articles` were available on this port. This bypasses any future nginx-only controls (TLS, headers, IP allowlists) and expands the attack surface. Werkzeug interactive debugger was not observed on a missing path.

Recommendation

Bind Gunicorn to localhost only and allow nginx to proxy it. Block port 5000 at the host firewall and security group. Confirm no other unexpected listeners remain.

M2: Missing CSRF protection on login and admin APIs	
Score	6.5 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N
Target	• https://www.thedownundernews.online/admin/login • /api/admin/users • /api/admin/articles • /api/admin/media/upload • /api/admin/comments
References	• CWE-352 • OWASP A01:2021

Overview

Admin actions (save articles, create users, reset passwords, upload files, delete comments) can be triggered with the browser session cookie and no extra one-time form token.

Details

The admin login form posts username and password to `/admin/login` with no CSRF token. Authenticated JavaScript uses `fetch(..., credentials: 'same-origin')` to `PUT`/`POST`/`DELETE` JSON admin APIs with only `Content-Type: application/json` and no CSRF header. Flask-JWT-Extended CSRF cookies were not present. Public article comments also POST with no token and are published immediately. Modern browsers may default unspecified SameSite to Lax, which reduces classic cross-site POST CSRF, but the application itself does not implement CSRF defenses.

Recommendation

Issue per-session CSRF tokens and require them on all state-changing requests. For cookie-based JWT, enable Flask-JWT-Extended CSRF protection. Add SameSite on cookies. Require moderation for comments.

M3: Session cookie missing Secure and SameSite flags	
Score	5.9 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:L/A:N
Target	https://www.thedownundernews.online/admin/login
References	• CWE-614 • CWE-1275 • OWASP A05:2021

Overview

After login, the website stores the signed-in session in a cookie that is allowed to travel over unencrypted HTTP and has no SameSite restriction set by the server.

Details

A successful login with an owner-provided dummy account issued `access_token_cookie`, a JWT (`alg: HS256`, `typ: JWT`, `type: access`) with `HttpOnly` and `Path=/` only. The `Secure` and `SameSite` attributes were absent. No CSRF cookie was issued. Port 80 is open and redirects to HTTPS, so a network attacker who can see HTTP requests could capture the session cookie. HttpOnly was present, which reduces simple JavaScript theft.

Recommendation

Set the session cookie with `Secure`, `HttpOnly`, and `SameSite=Strict` (or `Lax` at minimum). Serve HTTPS only and enable HSTS. Recreate sessions after the secret key rotation.

M4: Missing HTTP security headers	
Score	5.4 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	https://www.thedownundernews.online/
References	• CWE-693 • CWE-1021 • OWASP A05:2021

Overview

The website does not send standard browser security headers that help stop clickjacking, mixed content, and some cross-site script attacks.

Details

HTTPS responses from nginx included no `Strict-Transport-Security`, `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, or `Permissions-Policy`. The site can be framed by another origin (clickjacking), browsers will not enforce HTTPS on later visits (no HSTS), and there is no CSP fallback even though template injection and script gadgets are a concern.

Recommendation

Add HSTS (includeSubDomains), a strict CSP, `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`, `X-Content-Type-Options: nosniff`, and a conservative Referrer-Policy. Verify with securityheaders.com or equivalent after deployment.

M5: No DMARC policy for the corporate domain	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Target	thedownundernews.online
References	CWE-284

Overview

The domain has SPF via the registrar's mail forwarding, but no DMARC record. Others can more easily send email that looks like it comes from this domain.

Details

DNS for `thedownundernews.online` has `v=spf1 include:spf.efwd.spaceship.net ~all`. `_dmarc.thedownundernews.online` is NXDOMAIN. Mail hosts are registrar forwarding, not a company mail server. Missing DMARC weakens protection against spoofed mail to customers and partners.

Recommendation

Publish a DMARC record starting with `p=none` and a rua mailbox, then move to `quarantine`/`reject` after reviewing reports. Keep SPF aligned.

M6: Public articles API exposes staff account details	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	https://www.thedownundernews.online/api/articles
References	• CWE-200 • CWE-359 • OWASP A01:2021

Overview

The public news API returns more staff information than a reader needs, including account email, username, role, and whether the account is active.

Details

Unauthenticated GET `/api/articles` returns JSON with article objects whose `author` field includes `id`, `username`, `email`, `first_name`, `last_name`, `role`, `is_active`, and `created_at`. A live response included the admin username and an email on the `thedownundernews.it.com` domain. Passwords were not present. Related public endpoints `/api/categories` and `/api/search` are also reachable without authentication. This helps an attacker target staff accounts.

Recommendation

Return only public author display names on unauthenticated APIs. Keep emails, account status, roles, and internal IDs for authenticated admin endpoints. Review all `/api/*` serializers.

M7: Unauthenticated comments publish immediately	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Target	https://www.thedownundernews.online/article/welcome-to-the-down-under-news
References	• CWE-799 • CWE-352

Overview

Anyone can post a comment on an article without signing in, and the site says it will show immediately.

Details

The article page states “Your comment will appear immediately.” The form posts to `/article/<slug>/comment` with `author_name`, `author_email`, and `content` and no CSRF token. A previously posted comment was visible to the public. HTML in that comment was encoded in the page (so this is not stored XSS), but the feature still allows spam or defacement of the live newspaper without authentication or moderation. Admin comments showed no pending queue.

Recommendation

Require login or a CAPTCHA, hold comments for moderation, add CSRF tokens and rate limiting, and avoid publishing visitor email addresses in admin views more widely than needed.

M8: TLS certificate does not cover the apex hostname	
Score	4.2 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	https://thedownundernews.online/
References	CWE-295

Overview

The encrypted certificate is only valid for www. Visitors who type the address without “www” get a certificate warning.

Details

The live certificate CN/SAN is only `www.thedownundernews.online` (Let’s Encrypt, valid 2026-10-04 to 2027-01-02). `thedownundernews.online` resolves to the same IP and serves the site, but OpenSSL/curl report a name mismatch. Users may ignore the warning or fail to connect, and some clients will refuse the connection.

Recommendation

Issue a certificate with both `thedownundernews.online` and `www.thedownundernews.online`, or redirect apex HTTP/HTTPS to www before TLS on the wrong name (for example with a separate matching cert or DNS-only redirect).

I1: Contact form does not send messages	
Score	0.0 (Info)
Vector string	N/A
Target	https://www.thedownundernews.online/contact
References	-

Overview

The contact page looks like it sends a message, but it only shows a thank-you note in the browser and never talks to the server.

Details

The contact form handler calls `preventDefault()`, displays a success message, and resets the form. There is no POST to an API. Customers may believe a tip or correction was received when it was not. This is a reliability issue more than a classic exploit.

Recommendation

Wire the form to a server endpoint with CSRF protection, validation, and spam controls, or remove the fake success message.

I2: SSH reachable on the public web server	
Score	0.0 (Info)
Vector string	N/A
Target	51.161.130.70:22
References	CWE-668

Overview

Remote administration (SSH) is open on the same public server that hosts the website.

Details

Nmap showed OpenSSH 10.0p2 Debian 13 on TCP 22. No login guessing was performed. A current OpenSSH version reduces likely remote-code bugs, but a public SSH port is still a brute-force and exploit target if credentials or keys are weak.

Recommendation

Restrict SSH to trusted IPs or a VPN/bastion, use key-only authentication, disable password logins, and keep the package updated.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerabilty assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section

A.2 Methodology

The assessment followed a phased, non-destructive methodology:

1. Authorization check on the main public-facing website before any testing.
2. OSINT, DNS, and HTTP enumeration of company-related assets.
3. Owner confirmation of in-scope versus excluded assets.
4. Port discovery on 51.161.130.70 (top ports), then version detection on open ports only.
5. TLS inspection and HTTP security-header review.
6. Directory and API mapping of the public site and `/admin` CMS.
7. Authenticated review of the Flask/Gunicorn/nginx CMS using owner-provided dummy accounts (admin, writer, editor).
8. Targeted, non-destructive injection tests on search, API, and forms.

No denial-of-service, malware, phishing, brute force, credential stuffing, password spraying, MFA bypass, lateral movement, or destructive changes were used.

A.3 Limitations

The following limitations apply to this assessment:

- The media host (`media.thedownundernews.online` / 51.161.131.195) and the claimed `thedownundernews.it.com` domain were out of scope by owner selection.
- SQL injection automated scanning was not completed.
- Server-side template injection testing stopped at minimum proof. No remote-code-execution payload was used.
- The production secret key value was observed during testing and is **not** included in this report. It must be rotated.
- Testing was performed from a single vantage point on a single day (5 October 2026).
- Third-party infrastructure (OVH remainder, Spaceship DNS/mail, Google Fonts, jsDelivr, Flinders University, social networks, it.com parent) was excluded.

A.4 Coverage

Open ports identified on 51.161.130.70:

- 22/tcp — SSH (OpenSSH 10.0p2)
- 80/tcp — HTTP (nginx)
- 443/tcp — HTTPS (nginx)
- 5000/tcp — HTTP (Gunicorn)

Web application coverage:

- Public news website and `/admin` CMS (Flask / Gunicorn / nginx)
- Roles tested with owner-provided dummy accounts: admin, writer, editor
- Public search, articles API, comments, contact form, TLS, cookies, and security headers were reviewed on in-scope hosts